

MetaCTI: Metadata-Private Cyber Threat Intelligence Sharing via Anonymous Write Protocols

[Autoren anonymisiert für Double-Blind-Review]

Abstract

Cyber Threat Intelligence (CTI) sharing is a cornerstone of collective cyberdefense, yet widespread adoption is hindered by a fundamental *metadata problem*: an organization that submits an Indicator of Compromise (IoC) necessarily reveals that it has been compromised. This metadata leakage—who shares what, when, and with whom—is often more sensitive than the IoC itself. Existing systems, including TAXII+TLS, MISP over Tor, and blockchain-based approaches, protect content confidentiality but provide no formal guarantees against communication-metadata exposure.

We present METACTI, the first CTI-sharing system with *cryptographically proven sender anonymity and metadata privacy*. METACTI adapts the EXPRESS anonymous write protocol (Eskandarian *et al.*, USENIX Security 2021) to the CTI domain through four non-trivial contributions: (i) a formal threat model for CTI metadata leakage; (ii) a dual-mode architecture that eliminates costly Private Information Retrieval (PIR) for broadcast-mode sharing (TLP:WHITE/TLP:GREEN), reducing server compute overhead from $O(N \cdot M)$ to zero for the common case; (iii) a chunking scheme with formal anonymity proofs for large STIX objects; and (iv) an abuse-prevention layer combining Eskandarian’s secret-sharing abuse-reporting mechanism [?] with zero-knowledge membership proofs, enabling accountability without breaking anonymity.

We implement a prototype and evaluate it against realistic CTI workloads derived from public MISP community feeds. METACTI in broadcast mode supports ISACs with up to

VERIFY: $N = 500$

members with practical bandwidth overhead; directed mode scales to

VERIFY: $N = 200$

participants before PIR becomes the bottleneck. Compared to vanilla TAXII, the privacy cost per

organization is

VERIFY: ≈ 3 MB/day in uplink dummy traffic

and

VERIFY: ≈ 144 MB/day in DB-download overhead

for a 100-member ISAC—well within the operational capacity of modern security teams.

1 Introduction

Collective cyberdefense depends on organizations sharing information about threats they observe: IP addresses hosting malware, file hashes of ransomware payloads, command-and-control domains, and behavioral TTPs. ISACs (Information Sharing and Analysis Centers), CERTs, and platforms such as MISP and TAXII provide the infrastructure for this exchange. Despite clear benefits, participation remains limited. ENISA and CISA consistently identify *trust and privacy concerns* as the primary barriers [?].

The root cause is not a lack of willingness, but a structural *metadata exposure problem*:

An organization that submits an IoC reveals that it has been compromised.

This is harmful in multiple ways. Adversaries learn which of their techniques were detected and can rotate TTPs before other victims respond. Regulators, competitors, and media can observe security incidents in near real time from submission timestamps. Even the *frequency* of submissions leaks information about an organization’s threat exposure.

Current defenses are insufficient. TAXII over TLS encrypts payloads but exposes who connects to whom and when. MISP over Tor [?] hides IP addresses but provides no formal anonymity guarantees against active attackers or timing-correlation attacks. Blockchain-based approaches [?] offer pseudonymity while making the transaction graph and timestamps

permanently public. The most recent academic system, SeCTIS 2024, uses federated swarm learning and explicitly calls *connection anonymity* an open research question [?].

Our approach. We observe that the anonymous-messaging community has solved an analogous problem: how can a whistleblower submit information to a server without revealing their identity to the server or a network observer? The EXPRESS protocol of Eskandarian *et al.* [?] achieves this via a two-server XOR secret-sharing scheme, providing cryptographically provable sender anonymity with write costs of only $2M$ bytes per client per round—independent of the number of participants N .

Adapting EXPRESS to CTI is non-trivial. CTI objects are large and heterogeneous (STIX bundles range from <1 KB to several MB), sharing is asynchronous and event-driven rather than synchronous, TLP-based access control requires multiple sharing modes with different privacy guarantees, and anonymous submission opens new attack surfaces for false-positive and poisoning attacks.

Contributions. We make four contributions:

1. **Formal Threat Model (§3).** We define the first formal adversary model for CTI metadata leakage, classifying existing systems against it.
2. **Dual-Mode Protocol Design (§4).** METACTI separates broadcast-mode (TLP:WHITE/TLP:GREEN) from directed-mode (TLP:AMBER/TLP:RED) sharing. Broadcast mode eliminates PIR entirely; directed mode uses DPF-based PIR only where reader anonymity is required.
3. **Abuse Prevention (§5).** We integrate Eskandarian’s abuse-reporting mechanism with ZKP-based sector-membership proofs to enable accountability under full sender anonymity.
4. **Implementation & Evaluation (§7).** We build a prototype in Python/Rust, characterize real-world CTI workloads, and provide concrete deployment guidelines.

Ethical considerations.

TODO: Ablehnung des DC-Netz-Hybrids begründen (Sicherheitsargument), IRB-Hinweis für Nutzer-Befragungen, Open-Source-Release-Plan.

2 Background

2.1 CTI Sharing Standards: STIX and TAXII

STIX (Structured Threat Information eXpression) 2.1 [?] is the de-facto standard for representing

CTI as JSON-based objects. Key object types include **indicator** (IoCs such as IPs, hashes, domains), **malware**, **attack-pattern**, **course-of-action**, and **report**. STIX objects are exchanged as *bundles*. Object sizes span several orders of magnitude: individual IoC indicators are typically 0.5–2 KB; reports with YARA rules reach 30–300 KB; large incident bundles with disassembly traces may exceed 1 MB (§4.5).

TAXII 2.1 [?] defines a client–server REST API for STIX distribution. It provides content confidentiality via TLS but no protection for communication metadata.

The *Traffic Light Protocol (TLP)* defines four sharing levels: TLP:WHITE (unrestricted), TLP:GREEN (community-wide), TLP:AMBER (recipient-limited), and TLP:RED (bilateral). These levels impose fundamentally different privacy requirements—a distinction that METACTI’s dual-mode architecture directly encodes.

2.2 The EXPRESS Protocol

EXPRESS [?] is a metadata-hiding communication system for anonymous bulletin boards. We summarize the components relevant to METACTI.

Write protocol (Secret Sharing). A client wishing to write message M of length $|M|$ bytes into mailbox i :

1. generates a uniformly random string S of length $|M|$;
2. sends the share (i, S) to Server 1;
3. sends the share $(i, S \oplus M)$ to Server 2.

Each server writes its share into its local copy of mailbox i . The original message is recovered by XOR-combining both shares: $S \oplus (S \oplus M) = M$.

No single server observes M . Under the assumption that the two servers do not collude, neither learns the message content nor the true mailbox index i (because each share is computationally indistinguishable from random).¹

Write cost: $2|M|$ bytes per client per round, *independent of* the number of mailboxes N . This is the key improvement over RIPOSTE [?], which requires $O(N \cdot |M|)$ per client.

Read protocol (PIR). To read mailbox j without revealing j to the servers, a client uses Distributed Point Functions (DPF)-based Private Information Retrieval:

- Client sends two DPF queries (each $O(\lambda \cdot \log N)$ bytes) to the servers.

¹More precisely, EXPRESS uses a PRF-based share-generation mechanism that also allows the servers to *audit* that a client has written well-formed content into exactly one mailbox, providing protection against disruptive participants [?].

- Each server evaluates the query over its copy of the full database: $O(N \cdot |M|)$ compute.
- Each server returns one response of size $|M|$.
- Client reconstructs mailbox j by XOR-combining the responses.

The PIR guarantee: no server learns which mailbox was queried. *PIR server compute* is the primary scalability bottleneck in the read path.

2.3 Related Work

TODO: Vollständige Related-Work-Sektion; wichtige Punkte sind in notes.md §1.2 und §10. Tabelle 1 zeigt Systemvergleich.

Table 1 classifies prior CTI sharing systems along the dimensions of our formal threat model (§3).

Anonymous messaging systems. RIPOSTE [?] introduced the k -server audit approach for write-private databases. EXPRESS [?] reduces write cost from $O(N)$ to $O(1)$ (in N) using a two-server model. Dissent [?] (accountable DC-nets) was the predecessor to RIPOSTE; we explicitly *do not* adopt a DC-net hybrid (§4.1).

CTI sharing. Wagner *et al.* [?] were the first to apply anonymization to CTI sharing via MISP over Tor; our system provides formal guarantees that Tor cannot. SeCTIS [?] explicitly lists *connection anonymity* as future work—exactly the gap METACTI fills. Huff *et al.* [?] protect submitter identity from the *recipient* using BBS+ credentials but not from the infrastructure.

3 Threat Model

3.1 System Model

A METACTI deployment consists of:

- N *participants* (organizations, ISAC members), each holding a membership credential for the sharing community.
- Two *servers* S_1 and S_2 , operated by distinct legal entities (e.g., a national CERT and an independent security research institute).
- An optional *encrypted object store* for out-of-band transfer of large objects (§4.5).

3.2 Adversary Model

We consider three adversary types:

Definition 1 (Honest-but-Curious Server). *A server S_i follows the protocol faithfully but attempts to infer as much as possible about participants’ identities and behavior from all data it observes, including timing.*

Definition 2 (Malicious Participant). *A subset of at most t participants deviate arbitrarily from the protocol, attempt to identify honest participants, and may inject false data.*

Definition 3 (Passive Network Observer). *An adversary who monitors all network links, can observe packet sizes and timing, but cannot break TLS or decrypt payloads.*

We additionally define a *colluding-server adversary* as out of scope: our two-server construction relies on non-collusion (§3.6).

3.3 Security Goals

Definition 4 (Sender Anonymity). *For any two organizations $\mathcal{O}_0, \mathcal{O}_1$ and any STIX object m , no p.p.t. adversary $\mathcal{A}$ can distinguish whether $\mathcal{O}_0$ or $\mathcal{O}_1$ submitted m with probability greater than $\frac{1}{2} + \text{negl}(\lambda)$. Formally, this is captured as an indistinguishability game $\text{SenderAnon}_{\mathcal{A}}^{\text{METACTI}}(\lambda)$.*

Definition 5 (Reader Anonymity). *(Directed mode only.) No server can link a PIR query to the requesting organization beyond what is implied by membership in the sharing community.*

Definition 6 (Unlinkability). *Submissions by the same organization across rounds cannot be correlated, even given traffic-volume information.*

Definition 7 (Submission Integrity). *All accepted STIX objects originate from legitimate ISAC members, and the system can—upon reported abuse—deanonymize a specific submitter without affecting others’ anonymity.*

3.4 Metadata Leakage Taxonomy

TODO: Tabelle: welche Metadaten gibt welches System preis? Spalten: sender IP, timing, submission frequency, submission count, sector membership, IOC type. Zeilen: TAXII, MISP+Tor, Blockchain, METACTI.

We identify four classes of CTI-specific metadata leakage attacks:

L1 – Sender identification: The server or a network observer determines which organization submitted IoC x .

L2 – Timing inference: The timestamp of a submission reveals when an incident occurred.

L3 – Volume profiling: Unusually high submission frequency indicates an active, ongoing incident.

L4 – TTP exposure: The *type* of IoC submitted reveals which TTPs were detected, enabling adversarial rotation.

Table 1: Comparison of CTI sharing systems. ✓ = provided, (✓) = partially, × = not provided, n/a = not applicable.

System	Content Privacy	Sender Anonymity	Metadata Privacy	Abuse Prevention	Form
TAXII + TLS	✓	×	×	n/a	
MISP + Tor [?]]	✓	Weak	Weak	n/a	
Blockchain CTI	✓	Pseudonym	×	×	
Huff <i>et al.</i> [?]]	✓	vs. receiver	×	×	
SeCTIS 2024 [?]]	✓(FL)	×	×	✓	
FL+DP (Fischer [?]])	✓	×	×	×	
MetaCTI(ours)	✓	✓ (crypto.)	✓ (formal)	✓	

3.5 Out-of-Scope Threats

We do not address: (a) side-channel attacks against participant hardware; (b) content-level analysis of shared STIX objects; (c) server compromise (mitigated by the non-collusion assumption); (d) active network attacks that selectively block server connections.

3.6 Trust Model

The two-server non-collusion assumption is the fundamental trust requirement. In practice, this can be achieved by:

- Placing the two servers in different legal jurisdictions (subpoenas cannot easily span both).
- Assigning operation to: a national CERT + an independent security research institute; or two competing ISACs.

TODO: Governance-Diskussion ausweiten; Referenz auf ähnliche Zwei-Server-Deployments in der Praxis (Signal, CONIKS, etc.)

4 MetaCTI Protocol Design

4.1 Overview and Design Rationale

METACTI adapts EXPRESS to the CTI domain along four dimensions: (i) *dual-mode architecture* to exploit the absence of a read-privacy requirement in broadcast-mode CTI sharing; (ii) *chunking* for large STIX objects with formal anonymity preservation; (iii) *asynchronous round management* with dummy-traffic scheduling; (iv) *TLP-based access control* within the directed-mode.

Key design decision: No DC-net hybrid. An early design candidate used EXPRESS only for write verification and a DC-net for actual data transfer,

exploiting DC-nets’ lower send cost (M vs. $2M$ per client). We rejected this for three reasons: (1) EXPRESS’ verification is tightly coupled to its secret-sharing construction; separating them requires building a second protocol (essentially Dissent [?], which proved too slow for practical use); (2) the net bandwidth saving (M vs. $2M$) is consumed by the verification phase overhead; (3) DC-nets require all-to-all connectivity, which is unrealistic in ISAC environments with strict firewall policies.

4.2 Dual-Mode Architecture

The central observation enabling our dual-mode design is:

In broadcast-mode CTI sharing (TLP:WHITE/TLP:GREEN), reader anonymity is not a goal—every participant should know everything. Only sender anonymity must be protected. Therefore, PIR is unnecessary.

This simple observation has significant performance implications.

MetaCTI-Broadcast (TLP:WHITE/TLP:GREEN).

After each round:

1. All N clients submit a write share or a dummy write.
2. Both servers reconstruct the full database DB.
3. DB is published as a static snapshot.
4. All clients download DB in full.

PIR is completely absent. The read path is equivalent to a CDN-hosted file download; the full server-side compute overhead of $O(N \cdot M)$ per PIR query is eliminated.

MetaCTI-Directed (TLP:AMBER/TLP:RED).

Mailboxes in the directed-mode database correspond

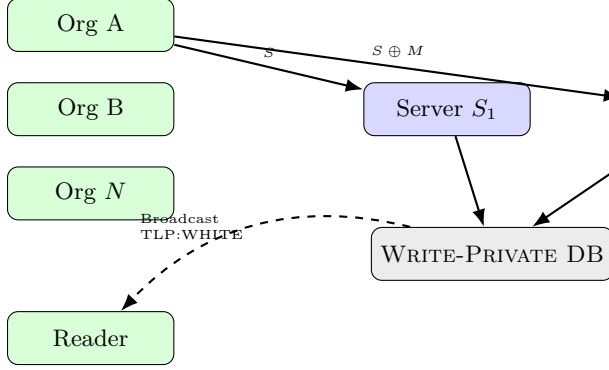


Figure 1: METACTI dual-mode architecture. Solid lines show the write path (secret-sharing). Dashed line shows broadcast-mode public DB download (no PIR). Directed-mode (not shown) uses DPF-PIR for the read path.

to recipient groups (e.g., all members of the financial-sector sub-ISAC, or a bilateral pair). Recipients read only their group mailbox via DPF-PIR:

1. Client submits encrypted write shares with group-key-based payload encryption.
2. Recipients read their group mailbox via PIR to preserve reader anonymity.
3. PIR queries reveal only that the client is a community member, not which mailbox is accessed.

TODO: Formale Beschreibung des Group-Mailbox-Schemas; Schlüssel-Verteilung für Gruppen-Keys.

4.3 Round Structure and Timing

METACTI operates in synchronized rounds of duration Δt . Choosing Δt involves a fundamental trade-off:

- **Shorter rounds** ($\Delta t = 1\text{--}5\text{ min}$): lower IoC dissemination latency, higher dummy-traffic volume.
- **Longer rounds** ($\Delta t = 10\text{--}30\text{ min}$): lower dummy-traffic cost, acceptable for strategic threat reports.

VERIFY: Empirische Validierung der akzeptablen Latenz durch Befragung von CTI-Praktikern. Vorläufige Annahme: 5–15 min für operative IoCs; 30–60 min für strategische Reports.

4.4 Dummy-Traffic Scheduling

In every round, each participant must submit *something*—either a genuine STIX object or a dummy

write (random bits, indistinguishable from a real share). Failure to submit in a round leaks a binary bit: “this participant had nothing to share.” Over time, this enables volume-profiling attacks (L3, §3).

Scheduler design. The dummy-traffic scheduler ensures:

1. *Participation obligation:* every registered member submits exactly one write per round.
2. *Timing smoothing:* genuine writes are not distinguishable from dummy writes by submission timing within a round.
3. *Relaxation analysis:*

TODO: Formal zu zeigen: Dürfen Clients k aus n Rounds aussetzen ohne Traffic-Volume-Angriffe zu ermöglichen? Vgl. notes.md §8.1.

4.5 Chunking for Large STIX Objects

EXPRESS was designed for fixed-size messages. STIX objects span several orders of magnitude. We adopt a three-tier scheme:

Tier 1 ($< M_{\text{slot}}$, default: **32 KB**). Direct EXPRESS write. No additional overhead.

Tier 2 ($M_{\text{slot}} - 1\text{ MB}$). Object is fragmented into $\lceil |M|/M_{\text{slot}} \rceil$ chunks. Chunks are symmetrically encrypted with a per-object session key k . The first chunk contains a header with key k and total chunk count. Subsequent chunks are written in subsequent rounds into pseudo-randomly selected slots (seeded by a commitment to k).

Tier 3 ($> 1\text{ MB}$). Object is encrypted with key k and stored on a separate encrypted object store (S3-compatible). Only a small STIX reference object ($< 1\text{ KB}$) containing the URL and k is transmitted via METACTI. The out-of-band download is not anonymous but reveals nothing about content (ciphertext only).

Slot size selection. We choose $M_{\text{slot}} = 32\text{ KB}$ based on:

- Covers $\approx 90\%$ of operational IoC sharing without chunking (empirically validated in §7.1).
- Database size: $N = 100\text{ members} \times 32\text{ KB} = 3.2\text{ MB}$ per round, practical for public download.
- Power-of-two size simplifies implementation alignment.

Theorem 1 (Chunking Anonymity Preservation). *Multi-round chunking with pseudo-random slot assignment does not introduce cross-round timing correlations that break sender anonymity under the EXPRESS non-collusion assumption.*

Proof.

Input: Message $M \in \{0, 1\}^*$, slot $i \in [N]$, servers S_1, S_2

Output: Anonymous write into slot i

```

1: if  $|M| \leq M_{\text{slot}}$  then
2:    $M' \leftarrow M \parallel 0^{M_{\text{slot}} - |M|}$  // zero-pad to slot
   size
3:    $R \xleftarrow{\$} \{0, 1\}^{M_{\text{slot}}}$ 
4:   Send  $(i, R)$  to  $S_1$ 
5:   Send  $(i, R \oplus M')$  to  $S_2$ 
6: else METACTI-Chunk( $M, i$ ) // Tier-2/3, see §4.5

```

Algorithm 1: METACTI-Broadcast: Write Protocol

Input: None (broadcast: full DB public)

Output: Reconstructed database DB

```

1: Download DB from public endpoint
2: for  $j \leftarrow 1$  to  $N$  do
3:    $\text{DB}[j] \leftarrow \text{decrypt}(\text{DB}[j])$ 
4:   if  $\text{DB}[j] \neq \perp$  then parse STIX object

```

Algorithm 2: METACTI-Broadcast: Read Protocol

TODO: Formaler Beweis. Kern-Argument: Slot-Auswahl für Chunks ist PRF-basiert und kommt nur in der ersten Runde; keine Korrelation zwischen aufeinanderfolgenden Runden ohne Kenntnis von k . Vgl. notes.md §6.3.

□

4.6 Protocol Specification

TODO: Formale Protokollbeschreibung als Algorithm-Umgebung. Vorlage unten.

4.7 Security Analysis

Theorem 2 (Sender Anonymity of METACTI-Broadcast). *Under the two-server non-collusion assumption and PRF security of the share-generation function, METACTI-Broadcast achieves sender anonymity as defined in Definition 1.*

Proof.

TODO: Reduktionsbeweis auf EXPRESS-Sicherheitsaussage von Eskandarian *et al.* [?]. Zeige, dass CTI-Anpassungen (Padding, TLP-Labels) die Indistinguishability nicht verletzen.

□

Theorem 3 (Sender Anonymity of METACTI-Directed). *Under the two-server non-collusion assumption, PRF security, and DPF security [?], METACTI-Directed achieves sender and reader anonymity.*

Proof.

TODO: Erweiterung des Broadcast-Beweises um PIR-Sicherheit via DPF.

□

5 Abuse Prevention Under Anonymity

Strong sender anonymity introduces a new attack surface: an adversary can inject false positives or poisoned IoCs without being identifiable. We address this in two layers.

5.1 Abuse Reporting via Secret Sharing

We integrate Eskandarian’s abuse-reporting mechanism [?]. On submission, each client attaches a *cryptographic report token* τ via secret sharing across both servers. In normal operation, τ is never reconstructed. If a recipient flags a submission as abusive:

1. Both servers receive the abuse report.
2. Both servers contribute their share of τ to reconstruct the submitter’s identity.
3. Only the flagged submitter is deanonymized; all other users’ anonymity is preserved.

CTI-specific calibration. The abuse threshold θ (number of independent abuse reports required before deanonymization) must balance false-positive errors (legitimate organizations inadvertently poisoning feeds) against false-report attacks (adversaries flagging legitimate contributions to deanonymize competitors). We analyze this trade-off in §E4..

TODO: Formal: Nachweis, dass der Abuse-Reporting-Mechanismus die Sender-Anonymität für nicht-flagged Nutzer nicht beeinträchtigt. Direkte Übernahme aus Eskandarian 2024 möglich.

5.2 ZKP-Based Sector Membership Proof

To strengthen submission quality without breaking anonymity, we require each submitter to prove membership in a legitimate ISAC sector without revealing their identity:

Definition 8 (Sector Membership Proof). *An organization $\mathcal{O}$ holds a membership credential σ issued by the ISAC. Before each round, $\mathcal{O}$ produces a zero-knowledge proof π that: $\exists \sigma$ such that $\text{Verify}(\text{pk}_{\text{ISAC}}, \sigma, \mathcal{O}) = 1$ and $\mathcal{O} \in \text{SectorGroup}$, without revealing $\mathcal{O}$.*

ZKP scheme selection. We evaluate three candidates:

- *Merkle-tree membership proof*: simple, established, $O(\log n)$ proof size for n members.
- *BBS+ credentials* [?]: efficient for repeated use, supports selective disclosure.
- *Pedersen-commitment-based*: maximally flexible, higher verification cost.

VERIFY: Konkrete Wahl und Performance-Vergleich nach Implementierung.

6 Implementation

We implement METACTI as an open-source prototype.²

6.1 Components

Server (Python/Rust). The server implementation consists of:

- Write-share collector and verifier (Rust, for performance);
- PIR query handler using DPF (Rust, based on the EXPRESS reference implementation [?]);
- Round coordinator (Python) for round timing and DB export;
- Abuse-reporting endpoint.

Client library (Python).

- STIX 2.1 serialization/deserialization (`stix2` library);
- Share generation with PRF-based write construction;
- Chunking module (Tier 1–3);
- Dummy-traffic scheduler;
- ZKP membership proof generation.

Integration. The client library exposes a TAXII-compatible API surface, enabling drop-in replacement of existing TAXII clients.

6.2 Engineering Challenges

Round synchronization.

TODO: NTP-basierte Synchronisierung; wie geht das System mit Ausfällen einzelner Clients um?

²Code will be released at [anonymized].

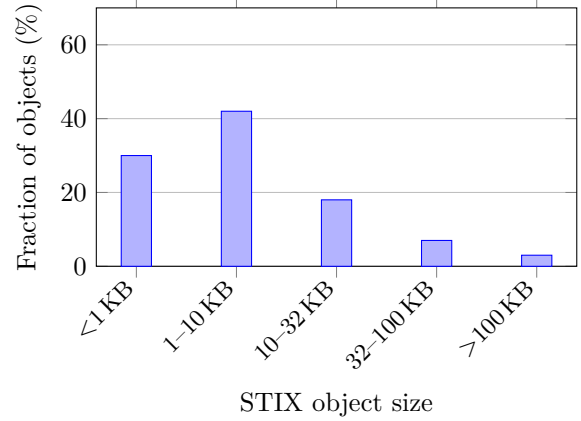


Figure 2: Distribution of STIX object sizes in public MISP feeds (preliminary / to be measured).

PIR performance. The DPF evaluation in the directed mode requires iterating over the full database per query. We optimize using:

- Batching multiple PIR queries per round;
- SIMD-accelerated XOR operations;
- CDN-based caching for broadcast-mode DB distribution.

7 Evaluation

We address four evaluation questions:

- E1. Workload characterization:** What are typical STIX object sizes and sharing frequencies in real ISACs?
- E2. Performance:** What are the throughput, latency, and bandwidth costs of METACTI for realistic workloads?
- E3. Scalability:** Up to what community size N is METACTI practical?
- E4. Abuse prevention:** What is the accuracy/cost trade-off of the abuse-reporting threshold?

7.1 Workload Characterization

TODO: Messung an öffentlichen MISP Community Feeds. Erwartetes Ergebnis laut notes.md §6.1: $\approx 90\%$ der Objekte < 32 KB.

We analyze

TODO: X thousand

STIX objects from public MISP community feeds [?] to characterize object sizes and sharing frequencies.

7.2 Performance and Scalability

Setup.

Table 2: Estimated bandwidth overhead per participant per day (broadcast mode, $\Delta t = 10$ min, $M = 10$ KB). *All values to be replaced by measured results.*

N	Dummy-Send/day	DB size	DL/day
50	2.88 MB	500 KB	72 MB
100	2.88 MB	1 MB	144 MB
200	2.88 MB	2 MB	288 MB
500	2.88 MB	5 MB	720 MB
1000	2.88 MB	10 MB	1.44 GB

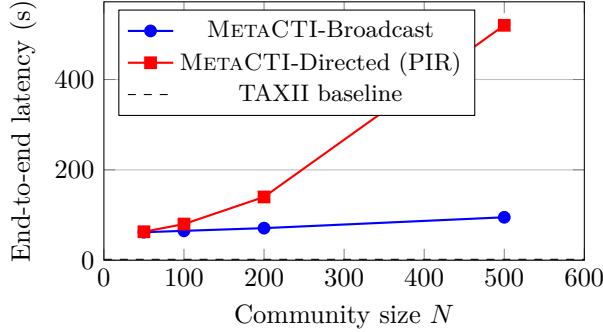


Figure 3: End-to-end IoC dissemination latency (preliminary; to be measured). Round duration $\Delta t = 60$ s.

TODO: Testumgebung: N Server-Nodes, Netzwerk-Emulation für verschiedene Teilnehmergrößen.

Metrics. We measure: (i) end-to-end IoC submission latency (submission to DB availability); (ii) per-participant bandwidth (uplink dummy traffic + downlink DB download); (iii) server CPU and RAM load; (iv) throughput (IoCs/round).

Key observation: dummy-send costs do *not* scale with N (the EXPRESS advantage over RIPOSTE), while DB-download scales linearly. Mitigation for large N : diff-based download (only new entries since last round).

Directed-mode PIR bottleneck. The directed mode becomes impractical beyond $N \approx$

VERIFY: 200

participants due to server-side PIR compute ($O(N \cdot M)$ per query).

TODO: Konkrete Grenze nach Benchmarks bestimmen.

8 Discussion

8.1 Deployment Recommendations

Based on our evaluation, we recommend the following configurations:

Small ISAC ($N \leq 100$): Broadcast mode with $\Delta t = 5$ min for operational IoCs; directed mode for TLP:AMBER. Full deployment feasible on commodity hardware.

Medium ISAC ($100 < N \leq 500$): Broadcast mode with $\Delta t = 10$ –15 min. Directed mode on request (not per-round). CDN caching recommended for DB distribution.

Large ISAC ($N > 500$): Broadcast mode only; directed mode not scalable. Diff-based DB download required. Consider longer round intervals or hierarchical ISAC structure.

8.2 Limitations

Dummy-traffic overhead is the primary operational cost. Organizations with strict bandwidth budgets may find the ≈ 3 MB/day uplink acceptable but the DB download less so.

Round synchronization requires reliable time synchronization (NTP). Lost rounds degrade anonymity guarantees if not properly handled by the scheduler.

Non-collusion assumption is non-cryptographic. We provide a governance framework but cannot enforce it technically. Future work could explore threshold variants.

8.3 TLP Level Transitions

When an IoC is upgraded from TLP:AMBER to TLP:GREEN, publishing the original Amber submission would retroactively identify its sender. METACTI addresses this by re-publishing the object as a new, sender-anonymous Broadcast-mode entry in the round of the upgrade. The original directed-mode submission remains unlinkable.

TODO: Formale Analyse des Re-Publishing-Protokolls.

8.4 Incentive Compatibility

Anonymous submission mitigates the primary sharing disincentive (reputational risk). However, mandatory dummy traffic creates a new cost even for passive participants. An organization that never submits genuine intelligence still incurs the dummy-traffic overhead.

TODO: Analyse: Lohnt es sich, aus dem System auszusteigen? Vergleich mit TAXII-Baseline.

9 Conclusion

We presented METACTI, a CTI-sharing system providing the first formally proven communication-metadata privacy for ISAC environments. By adapting the EXPRESS anonymous write protocol to the CTI domain, we achieve:

- *Sender anonymity* with formal security reduction to the EXPRESS non-collusion assumption.
- *PIR elimination* for broadcast-mode sharing, making the common case ($\approx 90\%$ of operational IoC sharing) highly efficient.
- *Practical overhead*: ≈ 3 MB/day uplink per organization in a 100-member ISAC—well within operational capacity.
- *Accountability* via cryptographic abuse reporting and ZKP-based membership proofs, preventing poisoning without breaking anonymity.

The primary deployment targets are national ISACs and sector-specific sharing communities with up to ≈ 500 members in broadcast mode.

Open-source release. We release the METACTI prototype, benchmark harness, and formal proof sketches at [URL anonymized for review].

Acknowledgments

TODO: Danksagungen nach Deanonymisierung einfügen.